

Lab2 COMSM0123 Network Security

Reconnaissance

In this lab, you will learn the basics and principles of network scanning and enumeration using Nmap.

Please read the **instructions** before solving any questions.

1. You can use your laptop (Kali Linux VM in Windows).
2. You will be working individually on this lab.

PLEASE NOTE: Mass scanning networks might be illegal in several countries and trigger NIDS in most public networks, including University of Bristol network (including eduroam).

Task - Nmap

Nmap ("Network Mapper") is an open-source tool for network exploration and security auditing. It was designed to rapidly scan large networks, although it works fine against single hosts. You can use it to discover hosts and services on a computer network, thus creating a "map" of the network. To ensure you understand the basics and principles of network scanning and enumeration with Nmap, you'll practise various types of scans. Please note ` -T5` is a useful flag for your searches that helps to speed them up. Example use `nmap -sn 192.168.1.0/24 -T5`

Task 1: Host discovery

An Nmap network sweep is a method to identify active devices on a network using the nmap -sn command, which performs a ping scan to find hosts without scanning their ports. To run a sweep, you use nmap -sn followed by the target IP range (e.g., 192.168.1.1/24) to quickly discover all live hosts on that network segment.

\$ nmap -sn 192.168.1.0/24

- **-sn:** This switch tells Nmap to perform host discovery without performing a port scan. This is also known as a "ping scan," and it helps you find which hosts are up in the given network.
- **192.168.1.0/24:** This is the target network range. It tells Nmap to scan the entire 192.168.1.0 to 192.168.1.255 address range.

Task 2: Port scans

> \$ nmap 192.168.1.1

This is a basic scan without any specific flags (options). By default, Nmap performs a SYN scan on the top (most common services to be listening) 1,000 ports.

> \$ nmap -sT 192.168.1.1

The **'-sT'** flag performs a TCP connect scan, attempting to establish a full TCP connection to each target port. This type of scan is more accurate but also more detectable.

```
> $ sudo nmap -sU 192.168.1.1
```

The **'-sU'** flag initiates a UDP scan. It's used to identify UDP services on the target host.

```
> $ nmap -p 80 192.168.1.1
```

The **'-p 80'** specifies the port number. Here, you are telling Nmap to scan only port 80 on the target host.

Task 3: Service scans

Point Nmap at a remote machine and it might tell you that ports 25/tcp, 80/tcp, and 53/udp are open. Using its nmap-services database of about 2,200 well-known services, Nmap would report that those ports probably correspond to a mail server (SMTP), web server (HTTP), and name server (DNS) respectively. This lookup is usually accurate—the vast majority of daemons listening on TCP port 25 are, in fact, mail servers. However, you should not bet your security on this! People can and do run services on strange ports.

Even if Nmap is right, and the hypothetical server above is running SMTP, HTTP, and DNS servers, that is not a lot of information. When doing vulnerability assessments (or even simple network inventories) of your companies or clients, you really want to know which mail and DNS servers and versions are running. Having an accurate version number helps dramatically in determining which exploits a server is vulnerable to. Version detection helps you obtain this information.

```
> $ nmap -sV 192.168.1.1
```

'-sV' enables version detection, allowing Nmap to determine service versions running on the open ports.

```
> $ nmap -O 192.168.1.1
```

'-O' attempts to identify the operating system running on the target host.

Task 4: Full scan

Aggressive Scan (-A): The -A flag is often called the "Aggressive" scan options. It is a convenience flag that activates four distinct features simultaneously. Instead of typing multiple flags, -A turns on:

1. **OS Detection (-o):** Guesses the Operating System based on how the target responds to TCP packets.
 2. **Version Detection (-sV):** Interrogates open ports to find exactly what software version is running (e.g., *Apache 2.4.41* instead of just *http*).
 3. **Script Scanning (-sC):** Runs the default set of NSE scripts to check for common vulnerabilities or information leaks.
 4. **Traceroute:** Traces the network path to the host to determine network topology.
- **Warning:** Because this runs scripts and attempts to fingerprint the OS, it generates significantly more network traffic than a standard scan. It is easily detected by Intrusion Detection Systems (IDS).

```
> $ nmap -A 192.168.1.1
```

Scanning All Ports (-p-) By default, Nmap only scans the top 1,000 most popular ports. Security administrators often move sensitive services (like SSH or RDP) to non-standard ports (e.g., port 2222 or 33899) to hide them.

- The -p- flag forces Nmap to scan every single TCP port from **1 to 65535**.
- **Note on Speed:** Scanning 65k ports takes a long time. When using -p-, it is highly recommended to add -T4 or -T5 to speed up the process, provided the network can handle it.

```
> $ nmap -p- 192.168.1.1
```

Task 5: Output

When performing comprehensive reconnaissance, simply viewing the results in the terminal is insufficient. You need to save the output in a format that can be easily parsed, stored, and integrated with other security tools.

XML Output (-oX)

XML (eXtensible Markup Language) is the recommended format for saving Nmap results for several key reasons.

- **Integrity and Detail:** The XML format includes the most comprehensive information available from the scan. It is extensible, meaning new Nmap features can be added without breaking existing programs that use the output.
- **Interoperability:** XML can be parsed by standard, free XML parsers available in all popular programming languages. This makes it the ideal format for programmers and for importing data into other applications like vulnerability scanners or Metasploit.
- **Format Stability:** Unlike other Nmap output formats, the structure of the XML output is less subject to regular changes, ensuring reliability for automated processing.

```
> $ nmap 192.168.1.1 -oX <filename>
```

The '**-oX**' switch tells Nmap to output the results in XML format. You need to specify a filename to save the results, like nmap_output.xml.

Investigate which other ways of output exist.

Task 6: Nmap Scripting Engine

While NSE has a complex implementation for efficiency, it is strikingly easy to use. Simply specify **-sC** to enable the most common scripts. Or specify the --script option to choose your own scripts to execute by providing categories, script file names, or the name of directories full of scripts you wish to execute. You can customize some scripts by providing arguments to them via the --script-args and --script-args-file options. The --script-help shows a description of what each selected script does. The two remaining options, --script-trace and -

-script-updatedb, are generally only used for script debugging and development. Script scanning is also included as part of the -A (aggressive scan) option.

Script scanning is normally done in combination with a port scan, because scripts may be run or not run depending on the port states found by the scan. With the -sn option it is possible to run a script scan without a port scan, only host discovery. In this case only host scripts will be eligible to run. To run a script scan with neither a host discovery nor a port scan, use the -Pn -sn options together with -sC or --script. Every host will be assumed up and still only host scripts will be run. This technique is useful for scripts like whois-ip that only use the remote system's address and don't require it to be up.

```
$ nmap -p 80 --script http-enum <Target_IP>
```